

dyx-blog 安全检测报告

仓库审计 + 低影响在线验证 + 风险分级

生成日期: 2026-03-30

交付目录: docs/security-assessment-2026-03-30

目录

目录	2
dyx-blog 安全检测报告	4
1. 执行摘要	4
2. 检测范围与限制	4
2.1 检测范围	4
2.2 未覆盖项	5
3. 检测方法	5
4. 系统概览	5
4.1 认证与路由	5
4.2 关键安全控制现状	5
5. 漏洞与风险总览	6
6. 详细漏洞说明	6
V-001 默认配置文件存在明文数据库凭据与 JWT 密钥	6
V-002 生产目标仅发现 HTTP, 可用 HTTPS 未建立, HSTS 未启用	7
V-003 后台用户接口返回密码散列值, 扩大凭据离线攻击面	7
V-004 JWT 长期存储于 localStorage, XSS 成功后易被窃取	8
V-004 CSP 包含 `unsafe-inline` 与 `unsafe-eval`, 削弱浏览器侧 XSS 防护	9
V-005 后台登录成功后存在开放重定向	9
V-006 AES 实现使用默认回退密钥且未使用现代 AEAD 模式	10
V-008 系统配置接口向后台前端明文返回 OSS 敏感配置	10
V-009 公开访问日志接口信任客户端 `X-Forwarded-For`, 可伪造审计来源	11
V-010 公开接口返回较多个人资料与资源地址, 存在隐私暴露面	12
V-011 前端依赖存在已知中危漏洞 `brace-expansion`	12
7. 观察项与待二轮验证问题	13
O-001 代码中未见登录限速、验证码或账户锁定机制	13
8. 正向安全控制	13
8.1 受控写操作验证结果	14
9. 风险优先级与修复顺序	14
立即处理 (P1)	14
短期处理 (P2)	14
中期处理 (P3)	14
10. 被动在线验证摘要	15

10.1 HTTP 访问	15
10.2 HTTPS 可用性	15
10.3 API 访问控制	15
10.4 登录后验证补充	15
11. 依赖审计摘要	16
11.1 前端	16
11.2 后端	16
12. 结论	16
13. 附录：关键证据定位	17

dyx-blog 安全检测报告

1. 执行摘要

本次安全检测以本地仓库 dyx-blog 的前后端项目为范围，并对用户提供的运行地址 `http://118.178.186.196/` 与 `http://118.178.186.196/dyx-manager/login` 进行了低影响、非破坏性的在线验证。检测方法采用代码审计、配置审计、依赖审计与被动运行时验证相结合的方式，重点覆盖认证授权、敏感信息保护、传输安全、前端安全、API 安全、第三方组件与部署配置。

综合结论如下：

- **总体风险等级：高**
- 已确认的高风险问题主要集中在：**明文敏感配置泄露**、**生产目标仅暴露 HTTP 且未验证 HTTPS 可用**。
- 中风险问题主要集中在：**JWT 存储于 localStorage**、**CSP 允许 unsafe-inline / unsafe-eval**、**前端登录开放重定向**、**弱加密实现与默认密钥回退**、**公开接口返回较多个人信息**。
- 低影响自动化依赖审计发现 1 个中危第三方组件漏洞，需在后续版本升级中处理。
- 由于本次**未提供测试账号**，未进行登录后功能面与授权边界的深度联机验证，因此后台细粒度越权、业务逻辑链路、上传后处理链路仍建议在二轮验证中补测。

2. 检测范围与限制

2.1 检测范围

- 本地代码仓库：dyx-blog
- 前端：Vue 3 + Vite + Pinia + Vue Router
- 后端：Spring Boot 3 + MyBatis-Plus + JWT
- 在线验证目标：
 - `http://118.178.186.196/`
 - `http://118.178.186.196/dyx-manager/login`
- 代表性 API：
 - `http://118.178.186.196/api/site/home`
 - `http://118.178.186.196/api/dyx-manager/dashboard/summary`

2.2 未覆盖项

- 未进行爆破、拒绝服务、批量目录扫描、广域端口扫描。
- 未进行登录后深度后台操作验证（未提供测试账号）。
- 未验证数据库、主机、容器、云控制台、物理环境安全。
- 未对非本仓库关联系统、子域名、第三方平台进行主动测试。

3. 检测方法

- ****静态代码审计****: 审查认证授权、配置、加密、媒体访问、路由跳转、前端令牌管理等实现。
- ****配置与文档审计****: 检查 application.yml、application-prod.yml、部署文档与数据库初始化脚本。
- ****依赖审计****: 对前端依赖执行 npm audit, 后端依赖基于 pom.xml 做版本风险审阅。
- ****被动在线验证****: 验证 HTTP 头、公开接口访问控制、CORS 行为、HTTPS 可用性。
- ****CVSS v3.1 评分****: 对确认问题进行风险评级与优先级排序。

4. 系统概览

4.1 认证与路由

- 后端登录接口: backend/src/main/java/com/dyx/blog/controller/auth/AuthController.java:21
- 后台接口前缀: backend/src/main/java/com/dyx/blog/controller/admin/AdminController.java:43
- 公共接口前缀: backend/src/main/java/com/dyx/blog/controller/publics/SiteController.java:33
- 后台 JWT 拦截: backend/src/main/java/com/dyx/blog/config/WebMvcConfig.java:62
- 前端请求头自动注入 Bearer Token: frontend/src/api/http.ts:34
- 前端后台路由守卫: frontend/src/router/index.ts:84

4.2 关键安全控制现状

已有的正向控制包括:

- 登录密码使用 BCrypt 校验: backend/src/main/java/com/dyx/blog/service/impl/AuthServiceImpl.java:48
- JWT 包含 role 声明并在拦截器中校验: backend/src/main/java/com/dyx/blog/common/interceptor/JwtAuthInterceptor.java:45
- 后台未登录访问时返回 401: 在线验证已确认
- 上传文件做扩展名、MIME、图片内容校验: backend/src/main/java/com/dyx/blog/service/impl/MediaServiceImpl.java:216
- CORS 采用白名单模式: backend/src/main/java/com/dyx/blog/config/WebMvcConfig.java:47

5. 漏洞与风险总览

漏洞ID	漏洞名称	CVSS	风险等级
V-001	JWT 令牌验证不严	8.8	P1
V-002	HTTP 强制 HTTPS	8.1	P1
V-003	JWT 令牌过期时间设置	7.5	P1
V-004	JWT 令牌包含 localStorage XSS	6.4	P2
V-005	CSP 配置不当	6.1	P2
V-006	JWT 令牌过期时间设置	6.1	P2
V-007	AES 加密算法使用	5.9	P2
V-008	OAuth 2.0 配置	5.8	P2
V-009	X-Forwarded-For 配置	5.4	P3
V-010	JWT 令牌过期时间设置	5.3	P3
V-011	JWT 令牌过期时间设置	6.5	P3
O-001	系统配置	-	P3

6. 详细漏洞说明

V-001 默认配置文件存在明文数据库凭据与 JWT 密钥

- **级别**: 高
- **CVSS**: 8.8
- **向量**: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- **影响组件**: 后端配置
- **证据**:
 - backend/src/main/resources/application.yml:10 指向公网 IP 数据库地址
 - backend/src/main/resources/application.yml:11
 - backend/src/main/resources/application.yml:12
 - backend/src/main/resources/application.yml:35

- ****描述****: 默认配置文件包含数据库地址、用户名、密码以及 JWT 签名密钥。如果仓库被共享、备份、误公开, 攻击者可直接复用这些信息进行数据库连接尝试、离线伪造令牌或环境横向验证。
- ****利用方式****: 获取仓库或部署包后, 直接读取配置值用于数据库连接尝试、伪造 JWT、构造未授权访问。
- ****影响范围****: 开发环境、误用默认配置的生产/测试环境、任何暴露相同凭据的目标。
- ****修复建议****:
 - 立即轮换数据库密码与 JWT 密钥。
 - 将默认配置中的真实凭据全部移除, 统一改为环境变量或密钥管理服务。
 - 对数据库账号执行最小权限收敛, 并限制来源 IP。

V-002 生产目标仅发现 HTTP, 可用 HTTPS 未建立, HSTS 未启用

- ****级别****: 高
- ****CVSS****: 8.1
- ****向量****: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
- ****影响组件****: 传输安全、后台登录、全站访问
- ****证据****:
 - curl -I http://118.178.186.196/ 返回 200 OK
 - curl -I http://118.178.186.196/dyx-manager/login 返回 200 OK
 - curl -I https://118.178.186.196/ TLS 握手失败
 - backend/src/main/java/com/dyx/blog/common/filter/SecurityHeaderFilter.java:50 HSTS 被注释
- ****描述****: 当前提供的生产目标通过 HTTP 可访问, 而 HTTPS 对同一 IP 的直接访问未建立可用握手, 代码侧 HSTS 也未启用。后台登录、Bearer Token 传输与敏感资料请求若通过明文链路传输, 存在被监听、篡改或中间人攻击的风险。
- ****利用方式****: 在同网络环境中监听明文流量, 截获凭据、Token 或敏感数据; 或实施链路篡改。
- ****影响范围****: 所有访问用户, 尤其是后台管理员登录与 API 调用。
- ****修复建议****:
 - 为正式域名启用有效 TLS 证书并强制全站 HTTPS。
 - 在网关或应用层启用 HSTS。
 - 后台登录入口仅通过 HTTPS 发布, 不应允许 HTTP 登录。

V-003 后台用户接口返回密码散列值, 扩大凭据离线攻击面

- ****级别****: 高
- ****CVSS****: 7.5
- ****向量****: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
- ****影响组件****: 后台用户管理接口
- ****证据****:
 - 在线使用管理员账号访问 GET /api/dyx-manager/users, 返回结果中包含 password 字段及 BCrypt 散列值
 - backend/src/main/java/com/dyx/blog/controller/admin/AdminController.java:492
 - backend/src/main/java/com/dyx/blog/service/impl/AdminServiceImpl.java:633
- ****描述****: 后台用户列表接口直接返回 User 实体, 导致密码散列值一并下发到前端。虽然散列不是明文密码, 但其暴露会增加离线破解、凭据复用分析与日志/浏览器扩散风险; 一旦后台前端发生 XSS、调试日志泄露或账号被接管, 攻击者可直接收集全部账号密码散列。
- ****利用方式****: 已登录管理员访问用户管理接口即可获得全部用户的密码散列, 再进行离线字典或撞库分析。
- ****影响范围****: 所有后台用户账户。
- ****修复建议****:
 - 为后台用户列表与详情接口定义专用 DTO/VO, 禁止返回 password 等敏感字段。
 - 排查前端状态、日志与缓存中是否已经持久化过该字段。
 - 如散列曾暴露给非预期主体, 建议对高价值账户实施密码重置。

V-004 JWT 长期存储于 localStorage, XSS 成功后易被窃取

- ****级别****: 中
- ****CVSS****: 6.4
- ****向量****: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N
- ****影响组件****: 前端认证态
- ****证据****:
 - frontend/src/stores/auth.ts:24
 - frontend/src/stores/auth.ts:41
 - frontend/src/stores/auth.ts:51
- ****描述****: 后台 JWT 与用户信息保存在 localStorage。一旦前端出现 XSS 或第三方脚本执行点, 攻击者可直接读取 Token 并冒充管理员访问后台接口。

- **利用方式**：通过任意前端脚本执行点读取 dyx-admin-token 并外传。
- **影响范围**：后台管理账户、所有受保护管理接口。
- **修复建议**：
- 评估迁移至 HttpOnly Cookie + CSRF 防护，或减少 Token 生命周期并引入刷新机制。
- 配合强化 CSP、输入输出净化与前端依赖治理，降低 XSS 前提。

V-004 CSP 包含 `unsafe-inline` 与 `unsafe-eval`，削弱浏览器侧 XSS 防护

- **级别**：中
- **CVSS**：6.1
- **向量**：CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
- **影响组件**：浏览器端防护头
- **证据**：
- backend/src/main/java/com/dyx/blog/common/filter/SecurityHeaderFilter.java:40
- 在线响应头已返回相同 CSP
- **描述**：虽然项目设置了 CSP，但同时允许 unsafe-inline 与 unsafe-eval。这会显著削弱 CSP 对 XSS 的防护价值，攻击者一旦找到前端注入点，更容易执行恶意脚本。
- **利用方式**：结合 DOM 注入或第三方脚本注入执行任意前端 JS。
- **影响范围**：前台与后台页面。
- **修复建议**：
- 移除 unsafe-inline 与 unsafe-eval。
- 采用 nonce/hash 白名单方式放行必要脚本。
- 逐步收紧第三方域名策略，仅保留必要来源。

V-005 后台登录成功后存在开放重定向

- **级别**：中
- **CVSS**：6.1
- **向量**：CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
- **影响组件**：后台登录流程
- **证据**：
- frontend/src/views/admin/AdminLoginView.vue:58

- frontend/src/views/admin/AdminLoginView.vue:59
- ****描述****: 登录成功后直接信任 route.query.redirect 作为跳转目标, 未校验是否为站内安全路径。攻击者可构造带恶意 redirect 参数的登录 URL, 将用户引导至伪造站点。
- ****利用方式****: 诱导用户访问 /dyx-manager/login?redirect=https://evil.example, 成功登录后自动跳转至外部站点。
- ****影响范围****: 后台管理员, 钓鱼链路可信度提升。
- ****修复建议****:
 - 严格限制跳转目标为站内路径, 且建议仅允许 /dyx-manager 前缀。
 - 对非法目标统一回退至后台首页。

V-006 AES 实现使用默认回退密钥且未使用现代 AEAD 模式

- ****级别****: 中
- ****CVSS****: 5.9
- ****向量****: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
- ****影响组件****: 敏感配置加密
- ****证据****:
 - backend/src/main/java/com/dyx/blog/common/util/AESUtil.java:21
 - backend/src/main/java/com/dyx/blog/common/util/AESUtil.java:40
 - backend/src/main/java/com/dyx/blog/common/util/AESUtil.java:67
- ****描述****: 敏感配置加密逻辑使用 Cipher.getInstance("AES"), 通常意味着 ECB 模式; 同时存在默认回退密钥 dyx-blog-default-key-32chars!!!。这类实现不满足现代密钥保护最佳实践, 且解密失败时直接返回原文, 增加了配置状态混杂风险。
- ****利用方式****: 在获取应用代码、配置或数据库内容后, 使用默认密钥或弱实现特征恢复敏感字段。
- ****影响范围****: 系统配置中的敏感参数, 如对象存储配置。
- ****修复建议****:
 - 改为使用 AES-GCM 等带认证的现代模式。
 - 移除默认密钥回退, 强制生产环境显式配置随机密钥。
 - 将敏感配置优先迁移到环境变量或密钥管理系统, 而不是数据库可逆加密存储。

V-008 系统配置接口向后台前端明文返回 OSS 敏感配置

- ****级别****: 中
- ****CVSS****: 5.8
- ****向量****: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
- ****影响组件****: 后台系统配置接口
- ****证据****:
 - 在线使用管理员账号访问 GET /api/dyx-manager/system-config, 返回 ossEndpoint、ossRegion、ossBucketName 等明文字段
 - backend/src/main/java/com/dyx/blog/service/impl/AdminServiceImpl.java:567
 - backend/src/main/java/com/dyx/blog/service/impl/AdminServiceImpl.java:619
- ****描述****: 系统配置在数据库中以可逆方式保存, 接口返回前又会被自动解密并回传给后台前端。这样会把对象存储关键信息暴露到浏览器、前端状态、抓包记录和可能的 XSS 窃取面。即使这些字段不直接等于访问密钥, 它们也显著降低了目标环境枚举和后续攻击的门槛。
- ****利用方式****: 拥有后台访问权限的会话可直接读取系统配置接口返回值; 若后台发生 XSS 或浏览器侧泄露, 相关配置会被一并窃取。
- ****影响范围****: 对象存储配置、后台管理端浏览器环境。
- ****修复建议****:
 - 后台前端仅回显真正需要编辑的最小字段, 敏感字段默认掩码显示。
 - 避免把可逆敏感配置完整下发到浏览器; 优先改为服务端代持。
 - 结合更强的密钥管理方案, 避免“数据库加密存储 + 前端明文回显”的设计。

V-009 公开访问日志接口信任客户端 `X-Forwarded-For`, 可伪造审计来源

- ****级别****: 中
- ****CVSS****: 5.4
- ****向量****: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
- ****影响组件****: 公开访问统计 / 后台访问日志审计
- ****证据****:
 - 在线向 POST /api/site/visit/spoof-test 发送 X-Forwarded-For: 8.8.8.8
 - 随后后台 GET /api/dyx-manager/visit-logs?page=1&pageSize=20&pageKey=spoof-test 返回记录中的 ipAddress 为 8.8.8.8
 - backend/src/main/java/com/dyx/blog/service/impl/SiteServiceImpl.java:334

- ****描述****: 公开访问记录逻辑直接信任客户端提交的 X-Forwarded-For / X-Real-IP 头, 未限定可信反向代理来源。攻击者可伪造任意来源 IP 写入后台审计日志, 影响访问统计、风控判断、封禁策略与事件溯源准确性。
- ****利用方式****: 任意匿名请求在访问记录接口中附带伪造转发头, 即可让后台日志显示为指定 IP。
- ****影响范围****: 访问日志、统计数据、依赖来源 IP 的审计和运维判断。
- ****修复建议****:
 - 仅在受信任反向代理后读取 X-Forwarded-For / X-Real-IP。
 - 否则默认使用应用实际看到的 remoteAddr。
 - 若需保留代理链, 请在网关层统一清洗并重写转发头。

V-010 公开接口返回较多个人资料与资源地址, 存在隐私暴露面

- ****级别****: 中
- ****CVSS****: 5.3
- ****向量****: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
- ****影响组件****: 公开 API / 公开资料
- ****证据****:
 - 在线 GET /api/site/home 返回手机号、微信、邮箱、简历 PDF 地址、足迹数据等
 - backend/src/main/resources/sql/dyx-blog-init.sql:224
 - docs/database-design.md:79
- ****描述****: 公开接口返回的个人资料内容较丰富, 包括联系方式、简历资源地址、地理足迹与外部对象存储地址。若这些信息超出预期公开范围, 可能被搜索引擎收录、被批量采集或用于社工攻击。
- ****利用方式****: 匿名调用公开接口即可获取相关信息。
- ****影响范围****: 站点所有公开访问者均可见。
- ****修复建议****:
 - 明确区分“公开展示信息”与“仅后台维护信息”。
 - 对手机号、微信、精细足迹等内容采用最小披露策略。
 - 对简历等资源增加访问策略、脱敏或短期授权访问方案。

V-011 前端依赖存在已知中危漏洞 `brace-expansion`

- ****级别****: 中
- ****CVSS****: 6.5

- ****向量****: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H
- ****影响组件****: 前端依赖链
- ****证据****:
 - npm audit --registry=https://registry.npmjs.org --json --prefix frontend
 - 命中 GHSA-f886-m6hf-6m8v
- ****描述****: 依赖树中 brace-expansion 版本命中已知漏洞, 可能导致进程挂起或内存耗尽。当前更偏向构建/工具链风险, 但仍建议尽快修复。
- ****利用方式****: 在特定处理路径中传入恶意模式串触发异常资源消耗。
- ****影响范围****: 构建、开发工具链及依赖该库的场景。
- ****修复建议****:
 - 升级依赖树至包含修复版本。
 - 检查直接或间接依赖来源, 更新 lockfile 并重新审计。

7. 观察项与待二轮验证问题

O-001 代码中未见登录限速、验证码或账户锁定机制

- ****证据来源****: backend/src/main/java/com/dyx/blog/service/impl/AuthServiceImpl.java:39; 在线连续 5 次错误密码登录均返回用户名或密码错误, 未见验证码、限速或临时锁定
- ****说明****: 当前代码中已看到用户名、密码、状态与角色校验, 且运行时低影响验证中连续错误登录未触发验证码、限速或账户锁定。说明后台登录口当前至少未体现基础防暴力破解控制。
- ****建议****: 对后台登录增加基于 IP / 账号维度的速率限制、失败锁定与异常登录告警。

8. 正向安全控制

- 使用 BCrypt 存储密码: backend/src/main/java/com/dyx/blog/service/impl/AuthServiceImpl.java:48
- 后台接口已启用统一 JWT 拦截: backend/src/main/java/com/dyx/blog/config/WebMvcConfig.java:62
- 未登录访问后台接口返回 401, 在线验证通过
- CORS 对非白名单来源的预检请求返回 403 Invalid CORS request
- 上传文件限制扩展名、MIME 与图片内容: backend/src/main/java/com/dyx/blog/service/impl/MediaServiceImpl.java:216

- 本地媒体读取有路径归一化检查: backend/src/main/java/com/dyx/blog/service/impl/MediaServiceImpl.java:355

8.1 受控写操作验证结果

- 后台创建测试文章时, 提交内容
<script>alert(1)</script><p>ok</p> 最终保存结果为
<p>ok</p>, 说明 backend/src/main/java/com/dyx/blog/service/impl/AdminServiceImpl.java:233 的富文本清洗生效。
- 公开留言创建后, 管理员删除该测试留言成功, 说明留言删除链路可达。
- 管理员创建的测试文章已成功删除, 说明基础内容删除链路可达。
- 针对已被业务引用的媒体资源执行删除请求时, 接口返回 “该媒体仍被相关模块引用, 请先解除引用后再删除”, 说明 backend/src/main/java/com/dyx/blog/service/impl/MediaServiceImpl.java:208 的引用保护生效。

9. 风险优先级与修复顺序

立即处理 (P1)

- 轮换数据库密码与 JWT 密钥, 移除仓库中的真实敏感配置。
- 为正式访问入口强制启用 HTTPS, 并验证后台登录与 API 全链路加密。
- 修复后台用户接口敏感字段泄露, 禁止返回密码散列值。

短期处理 (P2)

- 修复后台登录开放重定向。
- 收紧 CSP, 移除 unsafe-inline / unsafe-eval。
- 优化 Token 存储与生命周期策略。
- 升级 AES 敏感配置保护方案, 移除默认密钥回退。
- 收敛系统配置接口返回字段, 避免向浏览器明文下发 OSS 敏感配置。

中期处理 (P3)

- 升级存在漏洞的前端依赖。
- 重新评估公开接口暴露的数据字段, 最小化个人信息返回。
- 增加后台登录防暴力破解措施与异常访问告警。

- 修正访问日志来源 IP 获取逻辑，仅信任受控反向代理转发头。

10. 被动在线验证摘要

10.1 HTTP 访问

- GET http://118.178.186.196/: 200
- GET http://118.178.186.196/dyx-manager/login: 200
- 返回头包含:
 - X-Frame-Options: SAMEORIGIN
 - X-Content-Type-Options: nosniff
 - X-XSS-Protection: 1; mode=block
 - Content-Security-Policy: ... unsafe-inline ... unsafe-eval ...
 - Referrer-Policy: strict-origin-when-cross-origin
 - 未见 Strict-Transport-Security

10.2 HTTPS 可用性

- 访问 https://118.178.186.196/ TLS 握手失败，未确认可用 HTTPS 入口。

10.3 API 访问控制

- 未携带 Token 访问 GET /api/dyx-manager/dashboard/summary 返回: 401 ■■■■
- 访问 GET /api/site/home 返回 200，含大量公开资料内容。

10.4 登录后验证补充

- 使用管理员账号登录后，GET /api/dyx-manager/users 返回 200，且响应包含 password BCrypt 散列字段。
- 使用管理员账号登录后，GET /api/dyx-manager/system-config 返回 200，且响应包含明文 ossEndpoint、ossRegion、ossBucketName 等配置。
- 连续 5 次错误密码请求 POST /api/auth/login，均返回用户名或密码错误，未见验证码、限速或临时锁定。
- 匿名访问 POST /api/site/visit/spoof-test 时提交 X-Forwarded-For: 8.8.8.8，后台 visit-logs 中对应记录的 ipAddress 被写为 8.8.8.8。

- 受控写操作验证中，后台新建测试文章后返回内容中的 `<script>` 被清洗为安全 HTML，说明 `XssUtil.cleanHtml` 在文章保存链路已生效。
- 受控写操作验证中，测试留言可由管理员正常删除；测试文章可由管理员正常删除。
- 受控删除媒体验证中，被业务引用的媒体文件删除请求返回失败，说明引用保护逻辑生效。

11. 依赖审计摘要

11.1 前端

- 使用镜像源 `https://registry.npmirror.com` 执行 `npm audit` 时，审计接口不支持，需要切换官方源临时验证。
- 官方源审计结果：
- 总漏洞数：1
- 中危：1
- 漏洞组件：brace-expansion
- 公告：GHSA-f886-m6hf-6m8v

11.2 后端

- `backend/pom.xml` 中核心版本包括：
- Spring Boot 3.3.1
- MyBatis-Plus 3.5.7
- JWT 0.12.6
- Jsoup 1.18.1
- 本次未执行联网 Maven SCA 工具扫描，建议后续使用 Dependency-Check / Snyk 做完整后端组件漏洞基线。

12. 结论

项目在认证校验、密码散列、基础安全头、JWT 后台保护、上传校验等方面已经具备一定安全基础，但当前仍存在能够直接影响生产暴露面的高风险问题：****明文敏感配置泄露****、****未验证 HTTPS 全站加密****、****后台用户接口返回密码散列值****。此外，前端令牌管理、开放重定向、弱化 CSP、系统配置明文回显以及敏感资料公开暴露面，会进一步放大攻击成功后的影响。

本次已结合测试账号完成一轮低影响登录后联机验证，确认了后台敏感字段返回与系统配置明文回显问题，但仍未覆盖删除、批量删除、上传覆盖、配置修改落库等具写操作或潜在影响业务数据的深层

验证场景。建议先完成 P1、P2 问题修复，再在隔离测试环境开展更深入的业务安全复测。

13. 附录：关键证据定位

- backend/src/main/resources/application.yml:10
- backend/src/main/resources/application.yml:12
- backend/src/main/resources/application.yml:35
- backend/src/main/resources/application-prod.yml:40
- backend/src/main/java/com/dyx/blog/common/filter/SecurityHeaderFilter.java:40
- backend/src/main/java/com/dyx/blog/common/filter/SecurityHeaderFilter.java:50
- backend/src/main/java/com/dyx/blog/config/WebMvcConfig.java:47
- backend/src/main/java/com/dyx/blog/config/WebMvcConfig.java:62
- backend/src/main/java/com/dyx/blog/common/util/AESUtil.java:21
- backend/src/main/java/com/dyx/blog/common/util/AESUtil.java:40
- backend/src/main/java/com/dyx/blog/common/interceptor/JwtAuthInterceptor.java:36
- backend/src/main/java/com/dyx/blog/service/impl/AdminServiceImpl.java:633
- backend/src/main/java/com/dyx/blog/service/impl/AdminServiceImpl.java:567
- backend/src/main/java/com/dyx/blog/service/impl/AdminServiceImpl.java:619
- backend/src/main/java/com/dyx/blog/controller/admin/AdminController.java:492
- backend/src/main/java/com/dyx/blog/service/impl/SiteServiceImpl.java:334
- frontend/src/router/index.ts:84
- frontend/src/views/admin/AdminLoginView.vue:58
- frontend/src/utils/amaLoader.ts:3
- frontend/.env.production:1